

# Registro de Actividades de Tratamiento (RAT)

Inventario de qué datos personales trata el sistema, con qué finalidad, bajo qué base legal, quién accede y por cuánto tiempo se conservan. Documento exigido por la Ley 21.719 (y consistente con las obligaciones de custodia de la Ley 20.584 y de seguridad de la Ley 19.628) — issue #29 (T6.3), parte del plan de compliance derivado de la auditoría técnica y legal (14 jul 2026).

Este documento se deriva directamente del modelo de datos real ( `backend/prisma/schema.prisma` ) y de las decisiones ya implementadas en el código (versionado de consultas, ledger de consentimientos, bitácora de auditoría). Debe actualizarse cada vez que se agregue un modelo o un campo que trate datos personales.

## Responsable del tratamiento

Umbral - RCE, a través del sistema de gestión de fichas clínicas descrito en este repositorio.

## Inventario de actividades de tratamiento

| # | Actividad                   | Modelo(s) Prisma                                                                                                                  | Datos tratados                                                                    | Finalidad                                                | Base legal / consentimiento                                                                                            | Quién accede                                                                                                  | R                   |
|---|-----------------------------|-----------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------|----------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------|---------------------|
| 1 | Ficha clínica               | <code>Patient</code>                                                                                                              | Identificación, RUT, contacto, contacto de emergencia, médico/psiquiatra tratante | Prestación del servicio psicológico                      | Consentimiento informado — purpose <code>TREATMENT</code> en <code>PatientConsent</code>                               | Terapeuta tratante ( <code>therapistId</code> ); <code>SUPERVISOR</code> / <code>COORDINATOR</code> según rol | 15<br>20<br>(<br>bc |
| 2 | Consulta clínica            | <code>Consultation</code> + <code>ConsultationHistory</code>                                                                      | Motivo de consulta, intervención, acuerdos, próxima sesión                        | Registro obligatorio de cada sesión                      | Consentimiento <code>TREATMENT</code> ; versionado append-only ( <code>groupId</code> , <code>correctsId</code> )      | Terapeuta tratante; correcciones quedan en <code>ConsultationHistory</code>                                   | lg<br>ni<br>sc      |
| 3 | Telemedicina                | <code>Consultation.sessionType</code> = <code>TELEMED</code> , <code>PatientDocument.type</code> = <code>TELEMED_AGREEMENT</code> | Datos de la consulta + acuerdo de telemedicina firmado                            | Atención remota                                          | Consentimiento específico — purpose <code>TELEMEDICINE</code>                                                          | Terapeuta tratante                                                                                            | lg                  |
| 4 | Compartir con red de salud  | <code>PatientConsent</code> purpose <code>HEALTH_NETWORK</code>                                                                   | Datos clínicos ya existentes de la ficha                                          | Continuidad de atención con otro profesional/institución | Consentimiento explícito <code>HEALTH_NETWORK</code> , o acceso excepcional auditado de <code>SUPERVISOR</code> (T6.5) | Profesional autorizado; <code>SUPERVISOR</code> en modo excepcional                                           | lg<br>ex<br>re<br>A |
| 5 | Documentos adjuntos         | <code>PatientDocument</code> (consentimiento informado, informes, otros)                                                          | Archivos/PDFs vinculados al paciente                                              | Soporte de la ficha clínica                              | Consentimiento <code>TREATMENT</code>                                                                                  | Quien subió ( <code>uploadedBy</code> ) + terapeuta tratante                                                  | lg                  |
| 6 | Exportación de PDF de ficha | Servicio de reportes (acción <code>EXPORT_PDF</code> en <code>AuditLog</code> )                                                   | Ficha + historial clínico completo                                                | Entrega al paciente o a fiscalización                    | Deriva del consentimiento <code>TREATMENT</code> ya otorgado                                                           | Quien exporta, queda auditado                                                                                 | Hi<br>añ<br>irr     |

| #  | Actividad                                 | Modelo(s) Prisma                                                                                                                        | Datos tratados                                                  | Finalidad                                          | Base legal / consentimiento                                                   | Quién accede                                                                                             | R                                   |
|----|-------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------|----------------------------------------------------|-------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------|-------------------------------------|
| 7  | Bitácora de auditoría                     | AuditLog                                                                                                                                | Usuario, acción, recurso, IP, user agent, motivo de excepción   | Trazabilidad y evidencia ante fiscalización        | Obligación legal / interés legítimo — no requiere consentimiento del paciente | SUPERVISOR / ADMIN (lectura); inserción automática por el sistema, tabla append-only                     | 1!                                  |
| 8  | Historial de cambios de ficha             | PatientHistory (snapshot + diff)                                                                                                        | Ficha completa antes/después de cada edición                    | Trazabilidad de modificaciones a datos clínicos    | Deriva de TREATMENT                                                           | Quien edita ( changedBy ), auditoría                                                                     | lg                                  |
| 9  | Archivos compartidos (biblioteca interna) | SharedFile                                                                                                                              | Plantillas, formularios, protocolos — no son datos de pacientes | Recursos operativos del equipo                     | No aplica (no es dato personal de paciente)                                   | Todo el staff autenticado                                                                                | Si —                                |
| 10 | Backups                                   | Workflow<br>.github/workflows/backup.yml (fuera de Prisma; reemplaza a backups/backup.sh , pensado para una VM propia que ya no existe) | Volcado cifrado (AES-256, openssl ) de toda la base             | Continuidad operativa / recuperación ante desastre | Obligación de seguridad (Ley 19.628 art. 11 bis)                              | Quien tenga las credenciales de Backblaze B2 y la frase de cifrado (gestor de contraseñas del terapeuta) | Si to es KE de oc de de di "c de #& |

### Transferencia internacional de datos

Toda la tabla de arriba asume implícitamente que los datos se procesan en Chile, pero eso ya no es así:

- La base de datos primaria (**todas** las filas 1-9: fichas, consultas, documentos, auditoría, historial) vive en **Supabase, hospedado en São Paulo, Brasil**.
- La copia de backup (fila 10) vive en **Backblaze B2, hospedado en Estados Unidos** — mitigado parcialmente porque llega cifrada con AES-256 antes de subir, así que Backblaze nunca tiene acceso al contenido en claro (a diferencia de Supabase, que sí lo tiene por necesidad operativa: no se puede consultar/actualizar una ficha clínica sin que la base la lea en claro).

Esto constituye una transferencia internacional de datos de salud, que la Ley 21.719 regula explícitamente (requiere alguna base habilitante: nivel de protección adecuado del país destino, cláusulas contractuales con el proveedor, consentimiento explícito informado del paciente sobre dónde se almacenan sus datos, u otra excepción legal). **Esto no está resuelto ni evaluado legalmente** — determinar si la configuración actual (Supabase Brasil + Backblaze EE.UU.) cumple la Ley 21.719, y qué hace falta si no cumple (cláusulas contractuales, ajustar el texto del consentimiento informado, u otra medida), requiere revisión de alguien con conocimiento legal real, no es una decisión de ingeniería. Hasta que se resuelva, este punto queda documentado acá como riesgo abierto y conocido, no como algo ya evaluado y aceptado.

Evidencia recopilada hasta ahora (issue #55), guardada en docs/evidencia-compliance/ (snapshots en PDF, con fecha, de páginas públicas que los proveedores pueden actualizar):

- Supabase:** supabase-dpa-2026-08-03.pdf — el DPA se incorpora automáticamente al aceptar los Términos de Servicio (cláusula 12.2: "acceptance of the Agreement shall have the same effect as signing the SCCs"), sin firma separada. Confirmado por fuente oficial.
- Backblaze:** backblaze-dpa-eea-eu-2026-08-03.pdf + backblaze-tos-2026-08-03.pdf — mismo mecanismo de incorporación automática, pero el DPA público encontrado está textualmente acotado a "when GDPR applies" (UE/EEA). No confirma por sí solo que aplique a una transferencia desde Chile. Pendiente: respuesta de privacy@backblaze.com sobre si combinan su DPA/SCCs con las Cláusulas Contractuales Modelo (CCM) que el Ministerio de Economía de Chile aprobó en diciembre 2025 (Resolución RAEX202503748) para

transferencias bajo la Ley 21.719 -- ojo que la validez de esa aprobación ministerial también está en debate legal (¿le correspondía a la futura Agencia de Protección de Datos Personales, no al Ministerio?).

## Pendientes conocidos

---

- **Transferencia internacional de datos** — ver sección de arriba. Es el pendiente más importante de este documento hoy.
- **Firma electrónica avanzada** (filas 2 y 6, a futuro): la firma de cada consulta/corrección y el sello de tiempo en los PDF exportados dependen de elegir un proveedor acreditado por la Ley 19.799 — ver issues #24, #25, #26 (T5.1, T5.2, T5.3).

## Mantenimiento de este documento

---

Actualizar esta tabla cuando:

- Se agregue un modelo o campo nuevo en `schema.prisma` que trate datos personales de pacientes o usuarios.
- Se agregue una nueva finalidad de consentimiento ( `ConsentPurpose` ).
- Cambie algún plazo de retención o se resuelva alguno de los pendientes listados arriba.